# CyberCorp dossier de conception

*Infrastructure Windows sécurisée et audit contrôlé pour une soutenance Guardia*

Version 1.0 • 8 octobre 2026 • Document de conception et de recette

## Décision de conception

CyberCorp est une PME fictive de 25 employés. Le projet propose un laboratoire reproductible sur un mini-PC Windows 11 Pro avec Hyper-V et 16 Go de RAM, dont environ 11 Go disponibles. Il démontre la gestion des identités, le contrôle des accès, le filtrage réseau, la détection et la restauration à travers des scénarios bornés et documentés.

Le socle comprend Windows Server 2025 avec AD DS et DNS, un client Windows 11 Pro, pfSense et Kali Linux. Les VM sont exploitées par profils alternés pour conserver une marge de mémoire. Le MacBook accède uniquement à l'hôte via l'installation existante Tailscale puis RDP ; les VM sont administrées dans leurs consoles Hyper-V.

## Statut des informations

Les équipements et logiciels déjà présents sont déclarés par le porteur du projet ; ils n'ont pas été inspectés dans le cadre de ce dossier. Les adresses, règles, comptes, budgets et seuils sont des choix de conception. Tous les tests, incidents et mesures décrits sont à réaliser. Aucun résultat de recette, aucune conformité Guardia et aucune restauration réussie ne sont affirmés.

| Champ | Valeur |
|---|---|
| Auteur | Porteur du projet • identité à compléter |
| Destinataires | Jury Guardia et encadrant pédagogique |
| Classification | Pédagogique • données et identités fictives |
| Livrables | Dossier DOCX et PDF identiques ; preuves à constituer |
| Validation | Conception proposée ; recette non exécutée |

Le dossier sert de référence pour reconstruire le laboratoire, conduire l'audit, enregistrer les écarts et préparer la soutenance. Les licences, versions exactes et critères du cursus seront confirmés avant le déploiement.

# Sommaire et guide de lecture


| Page prévue | Contenu |
|---|---|
| 3 | Organisation et périmètre |
| 4 | Objectifs et exigences |
| 5 | Architecture et limites de confiance |
| 6 | Ressources et profils de démarrage |
| 7 | Plan IP et services réseau |
| 8 | Commutateurs Hyper-V et confinement |
| 9 | Politique pfSense et matrice des flux |
| 10 | Installation et séquence de construction |
| 11 | Domaine et organisation Active Directory |
| 12 | Comptes groupes et droits sur les fichiers |
| 13 | Stratégies GPO et postes Windows |
| 14 | Durcissement et accès distant |
| 15 | Menaces et matrice de risques |
| 16 | Scénarios contrôlés et règles de conduite |
| 17 | Plan d’audit et collecte |
| 18 | Journalisation et détection |
| 19 | Gestion des incidents et remédiation |
| 20 | Sauvegardes checkpoints et PRA |
| 21 | Recette fonctionnelle et isolation |
| 22 | Tests de sécurité avant et après |
| 23 | Indicateurs et critères d’acceptation |
| 24 | Matériel budget et charge de travail |
| 25 | Jalons et suivi du projet |
| 26 | Dossier de preuves et modèles |
| 27 | Déroulé de soutenance |
| 28 | Bonus GenOS en lecture seule |
| 29 | Commandes de vérification |
| 30 | Sources et glossaire |


Les numéros correspondent à la mise en page PDF de cette version. La pagination d’un DOCX peut varier selon le logiciel, les polices et les modifications. Lire les pages 5 à 9 avant toute connexion réseau et les pages 16 et 20 avant les essais.

# Organisation et périmètre

## Entreprise fictive

CyberCorp fournit du conseil et des services numériques à des clients professionnels. Les utilisateurs manipulent des dossiers clients, des contrats, des données financières fictives et des procédures internes. Le besoin principal est de limiter les accès par métier, maintenir l'authentification et prouver qu'un incident peut être détecté puis traité.

| Service | Effectif | Besoin métier |
|---|---|---|
| Direction | 2 | Lecture des synthèses et arbitrage des risques |
| Administration et RH | 3 | Gestion des dossiers RH |
| Finance | 3 | Écriture des documents financiers |
| Commercial | 7 | Gestion des dossiers clients |
| Technique | 8 | Projets et documentation technique |
| Informatique | 2 | Administration et support séparés des usages quotidiens |
| Total | 25 | 25 identités métier ; un seul poste représentatif |

## Périmètre inclus

- Un domaine AD, un contrôleur de domaine, DNS, GPO et un partage de fichiers pédagogique hébergé sur le même serveur.
- 25 utilisateurs fictifs, groupes par service, quelques comptes de test distincts et deux identités d'administration dédiées.
- Filtrage pfSense, réseaux privés Hyper-V, collecte locale de journaux et export de preuves.
- Audit autorisé, simulations sans malware réel, correction et démonstration d'une restauration.

## Exclusions et limites

Le réseau personnel, le MacBook, Internet et les services tiers ne sont pas des cibles. Pas de messagerie, SOC complet, SIEM lourd, IDS/IPS lourd, haute disponibilité ni 25 postes simultanés. Un seul serveur et un seul hôte constituent des points uniques de panne. L'hébergement du partage sur le DC est une concession pédagogique ; en entreprise, séparer les rôles et disposer de plusieurs DC sur des hôtes différents [S3].

Le jury reçoit des données fictives et des exports expurgés. Le projet démontre une démarche de sécurité ; il ne prétend pas reproduire les capacités d'une infrastructure de production pour 25 personnes.

# Objectifs et exigences

| ID | Exigence vérifiable | Validation prévue |
|---|---|---|
| E01 | Aucun pont direct entre réseaux d'audit ou métier et LAN personnel | T01 à T04 et inventaire des cartes |
| E02 | RAM VM simultanée au plus 9 Go selon profil | T05 et relevé mémoire hôte |
| E03 | Authentification AD et DNS interne cohérents | T06 et T07 |
| E04 | Accès aux fichiers selon métier avec refus vérifié | T08 et T09 |
| E05 | GPO appliquées avec trace de stratégie effective | T10 |
| E06 | Accès MacBook limité au RDP de l'hôte | T11 et contrôle de politique Tailscale |
| E07 | Essais autorisés et sortie WAN coupée pendant audit | T03 et fiche scénario |
| E08 | Traces corrélables et exportées avant retour arrière | T12 et T13 |
| E09 | Restauration mesurée depuis sauvegarde indépendante | T14 et T15 |
| E10 | Chaque constat relie preuve risque correction et contre-test | Registre de constats |
| E11 | Données fictives et secrets absents du dossier jury | Relecture des exports |
| E12 | GenOS facultatif sans droit de modification | G01 à G04 si activé |

## Exigences non fonctionnelles

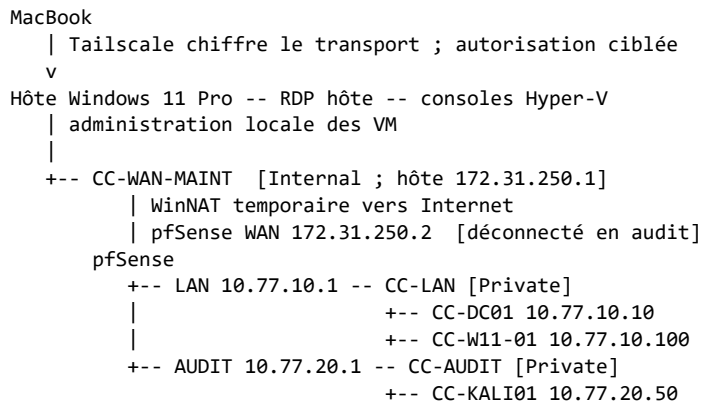
Disponibilité attendue pendant les séances planifiées ; l'extinction volontaire entre les séances est normale. Le laboratoire doit rester administrable avec les consoles Hyper-V même sans réseau. Les noms, IP et versions sont consignés afin de rendre les essais reproductibles. Toute exception de sécurité possède un motif, un propriétaire, une durée et un contre-test.

Les critères Guardia précis, la durée imposée et la grille de notation n'ont pas été fournis. Le dossier couvre la conception, l'implémentation planifiée, l'évaluation des risques, les preuves et l'analyse critique. Le porteur associera ces travaux aux compétences exactes de son cursus avec son encadrant.

## Livraison et responsabilités

Le porteur tient les rôles d'architecte, administrateur, auditeur et répondant incident, mais sépare leurs comptes et les phases de travail. L'encadrant valide le périmètre pédagogique. La direction fictive accepte les risques résiduels. Le jury apprécie les preuves et le raisonnement ; il ne remplace pas une homologation technique.

# Architecture et limites de confiance




CC-LAN est le LAN interne de l'entreprise fictive, mais son type Hyper-V est Private. Un commutateur Internal Hyper-V inclurait l'hôte ; ce n'est pas le choix pour les cibles. Aucun commutateur External ni Default Switch n'est attaché au client, au DC ou à Kali. pfSense seul relie les zones par des règles explicites [S1, S2].

## Deux modes réseau

Mode audit : carte WAN pfSense déconnectée dans Hyper-V, aucun flux Internet, réseaux Private maintenus. Mode maintenance : Kali éteinte et déconnectée, carte WAN branchée à CC-WAN-MAINT, NAT temporaire, sorties limitées aux mises à jour. Revenir au mode audit immédiatement après la maintenance et exporter l'inventaire des cartes.

## Limites de la protection

Le NAT ne constitue pas une isolation : il peut permettre l'accès au LAN personnel. La coupure physique virtuelle de la carte WAN en audit est donc le garde-fou principal. Le mode maintenance nécessite des blocages vers les destinations non publiques et l'hôte. Une compromission de l'hôte ou une mauvaise connexion de carte peut franchir les frontières ; cette limite demeure.

Tailscale est un réseau privé chiffré associé à des contrôles d'accès. Zero Trust est un modèle de confiance et d'autorisation, pas un domaine AD ni un protocole réseau unique. Le domaine ad.cybercorp.test fournit les identités Windows ; il ne désigne ni le tailnet ni un réseau Zero Trust [S6, S10].

# Ressources et profils de démarrage

| VM | RAM fixe | CPU virtuels | Disque dynamique | Rôle |
|---|---|---|---|---|
| CC-PFS01 | 1 Go | 1 à 2 | 20 Go | Filtrage sans paquets lourds |
| CC-DC01 | 4 Go | 2 | 80 Go système + 30 Go données | Server 2025 AD DNS partage |
| CC-W11-01 | 4 Go | 2 | 80 Go | Client Windows 11 Pro |
| CC-KALI01 | 2 Go | 2 | 40 Go | Audit en ligne de commande |

| Profil | VM actives | Total VM | Usage |
|---|---|---|---|
| Métier | pfSense + DC + client | 9 Go | AD GPO ACL et démonstration |
| Audit serveur | pfSense + DC + Kali | 7 Go | Scan DC et audit réseau |
| Audit client | pfSense + client + Kali | 7 Go | Pare-feu poste ; DC éteint |
| Restauration | pfSense + DC ou clone isolé | 5 Go | Recette PRA sans doublon AD |

Le démarrage des quatre VM demanderait 11 Go sans marge et est interdit dans ce dimensionnement. Les 11 Go libres sont une observation approximative de l'hôte ; mesurer avant chaque séance. Avec le profil métier, environ 2 Go de marge restent théoriquement disponibles, hors variations et frais Hyper-V. Si la mémoire réellement disponible tombe sous 1,5 Go, arrêter une VM ou réduire la charge applicative ; ne pas compter sur le swap pour rendre la soutenance fluide.

### Hypothèses matérielles à confirmer

CPU x64 avec virtualisation et SLAT, stockage SSD, capacité libre recommandée de 250 à 300 Go pour les VHDX, ISO, exports et marge de fusion. La somme des tailles maximales des VHDX atteint 250 Go ; leur taille actuelle augmente avec l'usage. Réserver un support de sauvegarde indépendant d'au moins 500 Go, idéalement 1 To. Conserver 20 % d'espace libre et suspendre les essais si l'espace devient insuffisant.

Client Windows 11 en génération 2, UEFI, Secure Boot et vTPM avec stockage 64 Go minimum et RAM 4 Go minimum [S4]. Choisir Server avec interface graphique pour la démonstration ; Server Core est une variante plus légère, non nécessaire. pfSense et Kali utilisent la génération compatible avec leurs images ; Secure Boot doit suivre les instructions de l'éditeur, sans le désactiver sur l'hôte.

Dans le profil audit client, les connexions AD utilisent éventuellement le cache : ce profil ne valide jamais une authentification fraîche au domaine. Les vérifications AD se font dans le profil métier ou audit serveur. Les vCPU sont partagés, leur addition n'équivaut pas à des cœurs physiques dédiés.

# Plan IP et services réseau

| Élément | Adresse IPv4 | Passerelle | DNS |
|---|---|---|---|
| WAN maintenance hôte | 172.31.250.1/24 | Aucune sur cette carte | Ne pas modifier le DNS hôte |
| pfSense WAN | 172.31.250.2/24 | 172.31.250.1 | Résolveur validé pour maintenance |
| pfSense LAN | 10.77.10.1/24 | WAN si maintenance | Sans résolution AD autonome |
| CC-DC01 | 10.77.10.10/24 | 10.77.10.1 | 10.77.10.10 |
| CC-W11-01 | 10.77.10.100/24 | 10.77.10.1 | 10.77.10.10 uniquement |
| pfSense AUDIT | 10.77.20.1/24 | WAN si maintenance | Sans DHCP |
| CC-KALI01 | 10.77.20.50/24 | 10.77.20.1 | 10.77.10.10 si règle audit autorisée |

Vérifier que ces préfixes ne chevauchent pas le LAN personnel, les VPN, les réseaux Docker/WSL et les routes existantes. Si un conflit existe, remplacer le préfixe partout avant installation. Les adresses Tailscale restent celles déjà attribuées ; ne pas inventer une IP 100.x pour l'hôte.

## Nommage et DNS

Forêt et domaine : ad.cybercorp.test ; nom NetBIOS : CYBERCORP. Le suffixe .test est réservé aux tests et ne suppose aucun domaine public acheté [S11]. Créer la zone inverse 10.77.10.0/24 et vérifier les enregistrements A, PTR et SRV AD. Autoriser les mises à jour dynamiques sécurisées sur la zone intégrée AD. Le DC a une seule carte LAN ; aucune carte WAN ou AUDIT.

Le client utilise le DNS du DC, jamais un DNS public en secondaire. En audit hors ligne, les requêtes externes peuvent échouer normalement. En maintenance, le DC peut transmettre les noms non internes à pfSense ou à un résolveur externe approuvé. Documenter ce chemin ; couper les redirecteurs si inutiles. Désactiver les mises à jour DNS automatiques du WAN virtuel sur l'hôte pour éviter la pollution de sa résolution.

## DHCP et horloge

Le socle utilise des IP fixes pour faciliter la recette. DHCP pfSense reste désactivé. Une extension DHCP pourra fournir une plage .100 à .149 avec DNS .10 et passerelle .1, après suppression des conflits statiques. Le PDC émulateur est la référence de temps du domaine ; en maintenance, synchroniser sa source approuvée, puis le client avec le domaine. En audit hors ligne, vérifier la dérive avant les scénarios et la consigner ; viser moins de 5 secondes pour corréler les traces.

Ne pas désactiver IPv6 sur les Windows AD de manière générale. Aucun routage IPv6 vers l'extérieur n'est fourni ; pfSense n'annonce pas de préfixe et applique un refus IPv6 explicite interzones. Les adresses link-local Windows restent locales ; elles ne doivent pas créer de chemin de contournement.

# Commutateurs Hyper V et confinement

## Configuration cible

| Commutateur | Type | Cartes admises | Interface hôte |
|---|---|---|---|
| CC-LAN | Private | DC client et LAN pfSense | Aucune |
| CC-AUDIT | Private | Kali et AUDIT pfSense | Aucune |
| CC-WAN-MAINT | Internal | WAN pfSense uniquement | 172.31.250.1 ; maintenance |

Ne pas activer le partage de connexion Internet, le pont Windows, RRAS ou un routage de sous-réseaux Tailscale. Ne pas donner une seconde carte au DC, au client ou à Kali. Le Default Switch peut exister sur l'hôte mais aucune VM CyberCorp ne doit y être connectée. WinNAT supporte des contraintes de coexistence : inventorier les NAT existants et ne jamais les supprimer en masse [S1].

## Garde fous de maintenance

- Kali arrêtée avec carte déconnectée avant branchement WAN. Aucun scénario d'attaque en maintenance.
- pfSense bloque en tête de règles tout accès vers RFC1918 hors besoins internes, 100.64.0.0/10, réseaux link-local, multicast et plages spéciales ; ajouter les IP de l'hôte et le sous-réseau personnel réellement observé.
- Autoriser ensuite les seuls flux nécessaires : DC et client vers destinations publiques en TCP 80/443 pendant une fenêtre ; pfSense vers DNS et NTP approuvés.
- Pare-feu hôte actif : bloquer les connexions entrantes depuis CC-WAN-MAINT vers les services de l'hôte. NLA et restriction RDP à l'identité et à la source Tailscale prévues.
- Aucune redirection de port WinNAT/pfSense ni UPnP/NAT-PMP. Contrôler les états et les réinitialiser après changement de règles.

## Passage en audit

1. Terminer les mises à jour et redémarrages. 2. Déconnecter la carte WAN de CC-PFS01 dans Hyper-V. 3. Exporter les cartes et les règles effectives. 4. Confirmer absence de chemin Internet et absence de carte physique sur les cibles. 5. Démarrer Kali sur CC-AUDIT. 6. Exécuter T01 à T04 avant toute simulation. En cas d'écart, arrêter Kali et corriger la topologie.

Le blocage sur pfSense est utile mais insuffisant si le pare-feu est compromis. La déconnexion WAN réduit ce risque pendant les attaques. L'hôte reste une frontière privilégiée : administrer uniquement depuis sa console, conserver Defender actif, supprimer les échanges presse-papiers/disques non nécessaires avec les invités.

Si WinNAT est incompatible avec l'existant, maintenir le laboratoire hors ligne et préparer des mises à jour via des images vérifiées. Ne pas improviser un WAN External vers le LAN domestique pour contourner une difficulté.

# Politique pfSense et matrice des flux

Les règles pfSense s'appliquent sur l'interface d'entrée et leur ordre compte [S5]. Supprimer le LAN allow any par défaut après création des autorisations utiles. Remplacer l'anti-lockout seulement après avoir vérifié l'accès de gestion et la console de secours. Le WAN privé nécessite l'adaptation du blocage automatique des réseaux privés sur WAN ; cela ne justifie aucune ouverture entrante.

| Entrée | Source vers destination | Service | Décision |
|---|---|---|---|
| WAN | Toute source vers laboratoire | Tous | Refus ; aucune publication |
| LAN | CC-W11-01 vers LAN pfSense | HTTPS 443 | Gestion temporaire par admin ; retirer après |
| LAN | DC vers pfSense | DNS 53 TCP/UDP ; NTP UDP 123 | Maintenance seulement si utilisés |
| LAN | DC/client vers non public ou hôte | Tous | Refus journalisé avant sorties publiques |
| LAN | DC/client vers Internet public | TCP 80/443 | Maintenance limitée ; audit WAN coupé |
| AUDIT | Kali vers pfSense | ICMP ; pas de GUI/SSH | ICMP temporaire ; gestion refusée |
| AUDIT | Kali vers DC ou client ciblé | Ports du scénario uniquement | Autorisation temporaire journalisée |
| AUDIT | Kali vers autres destinations | Tous | Refus journalisé |
| Toutes | IPv6 interzones ou extérieur | Tous | Refus ; pas de NAT IPv6 implicite |

## Flux AD et filtrage local

DC et client sont dans le même segment : leur trafic ne traverse pas pfSense. Le pare-feu Windows doit autoriser les fonctions AD nécessaires dans le profil Domaine, dont DNS 53 TCP/UDP, Kerberos 88 TCP/UDP, LDAP 389 TCP/UDP, SMB 445 TCP, RPC 135 TCP et RPC dynamique TCP 49152 à 65535 ; NTP 123 UDP, changement de mot de passe 464 TCP/UDP et catalogue global 3268 TCP selon usage. LDAPS 636 et GC TLS 3269 exigent une configuration de certificat, non supposée existante [S7].

Ne pas autoriser toute cette plage RPC depuis Kali par commodité. Pour S01, ouvrir temporairement les seuls ports scannés vers 10.77.10.10. Pour S02, SMB 445 suffit au test de droits. Les listes d'alias sont CC_DC, CC_CLIENT, CC_KALI, CC_NONPUBLIC et CC_ADMIN_TEMP. Documenter l'heure d'expiration de chaque règle.

## NAT et gestion

NAT sortant du LAN vers l'IP WAN pfSense, puis WinNAT sur l'hôte : double NAT acceptable pour ce laboratoire. Aucun NAT entre AUDIT et LAN, afin de conserver 10.77.20.50 dans les traces des cibles. Pas de NAT entrant. Gestion HTTPS depuis le client en profil métier uniquement avec compte pfSense nominatif ; console Hyper-V en secours. Sauvegarder config.xml après chaque changement significatif, en protégeant les secrets qu'il contient.

# Installation et séquence de construction

| Étape | Action | Point de contrôle |
|---|---|---|
| 1 | Inventorier matériel RAM SSD versions NAT routes et accès RDP existant | Fiche hôte ; pas de changement du lien distant |
| 2 | Obtenir ISO officiels et droits de licence ; enregistrer empreintes | Manifeste ISO et conditions d'usage |
| 3 | Créer les trois commutateurs et VM hors ligne | Inventaire cartes ; aucun External |
| 4 | Installer pfSense ; associer interfaces par MAC | Console LAN/AUDIT/WAN ; refus par défaut |
| 5 | Installer Server 2025 et fixer IP/nom ; ajouter AD DS et DNS | Nouvelle forêt ; mot de passe DSRM gardé hors preuves |
| 6 | Créer OU groupes et utilisateurs fictifs ; données de test | Export anonymisé de la structure |
| 7 | Installer client Windows 11 Pro ; joindre domaine | DNS correct et connexion utilisateur |
| 8 | Créer ACL GPO audit et stratégies de sécurité | gpresult ; tests fonctionnels avant durcissement |
| 9 | Maintenance contrôlée puis WAN déconnecté | Patchs redémarrés et T01 à T04 |
| 10 | Sauvegarder ; préparer baseline et scénarios | Copie indépendante et checkpoints cohérents |
| 11 | Audit correction et contre-tests | Constats et preuves avant/après |
| 12 | PRA final et répétition de soutenance | Chronométrage réel à renseigner |

### Choix et précautions de déploiement

Installer une version pfSense CE et Kali stable provenant de leurs éditeurs, consigner le numéro exact et la date de téléchargement. Ne pas annoncer une version installée sans lecture du système. Les évaluations Windows ont des conditions et durées à vérifier sur les pages officielles ; prévoir une licence ou un droit pédagogique valide pour la soutenance.

Configurer la carte DC avant promotion. Créer un domaine neuf plutôt que recopier un ancien DC. Choisir un mot de passe DSRM distinct du compte administrateur et le stocker dans un gestionnaire de mots de passe. Ne jamais joindre l'hôte Windows ou le MacBook au domaine de laboratoire.

Après chaque étape, conserver un export de configuration lisible et vérifier que le client reste fonctionnel. Appliquer les GPO progressivement à une OU de test. Enregistrer les exceptions avant de poursuivre ; aucun script d'installation du dossier n'a été exécuté sur les VM.

# Domaine et organisation Active Directory

```
ad.cybercorp.test  [CYBERCORP]
 +-- Domain Controllers        [CC-DC01 ; OU native]
 +-- OU=CyberCorp
      +-- OU=Utilisateurs
      |    +-- Direction / RH / Finance
      |    +-- Commercial / Technique / Informatique
      +-- OU=Postes            [CC-W11-01]
      +-- OU=Groupes           [globaux et locaux de domaine]
      +-- OU=Admins            [comptes dédiés]
      +-- OU=Tests             [identités bornées]
      +-- OU=Desactives        [comptes sortants]
```

Ne pas déplacer le DC dans une OU de postes. Créer les 25 comptes métier par service à partir d'un CSV sans mot de passe en clair. Utiliser des noms fictifs comme prenom.nom ou usr.fin01. Les comptes de scénario tst.acl et tst.lock sont supplémentaires et exclus du total des salariés. Désactiver ces comptes hors séance ; inscrire leur date d'expiration.

## Cycle de vie

- Arrivée : validation du service fictif, création dans la bonne OU, groupes de métier minimaux, mot de passe initial communiqué hors dossier et changement requis.
- Mobilité : retirer les anciens groupes avant ajout des nouveaux ; refaire le test d'accès avec une nouvelle session pour renouveler le jeton.
- Départ : désactiver immédiatement, retirer privilèges et sessions, déplacer dans Desactives ; suppression ultérieure selon la règle du laboratoire.
- Revue : export de membres des groupes sensibles à chaque jalon ; aucune appartenance Domain Admins accordée aux utilisateurs métier.

## Administration

adm.ad01 et adm.ad02 représentent les deux administrateurs. Leurs comptes métier Informatique restent standards. Réserver l'appartenance Domain Admins aux opérations qui l'exigent ; une délégation sur OU=Tests permet de réinitialiser les mots de passe de test sans administrer toute la forêt. Aucun compte partagé pour les essais.

Le compte Administrator intégré reste hors usage quotidien et son secret est protégé. Prévoir une récupération DSRM documentée, distincte du compte local administrateur du client et du compte administrateur de l'hôte. Aucun compte Domain Admin n'ouvre une session sur le poste utilisé comme cible d'audit.

Une seule forêt et un seul domaine suffisent pour ce scénario. Les OU organisent la délégation et les GPO ; elles ne constituent pas à elles seules une frontière de sécurité. Ne pas revendiquer un cloisonnement fort entre administrateurs de domaine et données hébergées sur le DC.

# Comptes groupes et droits sur les fichiers

Modèle AGDLP : comptes → groupes globaux de métier → groupes locaux de domaine portant les permissions. Exemple : usr.fin01 → GG_FINANCE → DL_FINANCE_MODIFY → dossier D:\Partages\Finance. Ne pas attribuer directement les droits aux utilisateurs, sauf exception documentée.

| Ressource | Groupes autorisés | Droit NTFS |
|---|---|---|
| Commun | GG_TOUS via DL_COMMUN_READ ; GG_IT via DL_COMMUN_MODIFY | Lecture ; modification IT |
| Finance | GG_FINANCE via DL_FINANCE_MODIFY | Modification |
| RH | GG_RH via DL_RH_MODIFY | Modification |
| Clients | GG_COMMERCIAL via DL_CLIENTS_MODIFY | Modification |
| Technique | GG_TECHNIQUE via DL_TECH_MODIFY | Modification |
| Syntheses | GG_DIRECTION via DL_SYNTHESES_READ ; responsables désignés via DL_SYNTHESES_MODIFY | Lecture ; modification limitée |

## Mise en œuvre des ACL

Partager chaque dossier via \\CC-DC01\Finance, RH, Clients, Technique, Commun et Syntheses. Donner aux groupes locaux concernés le droit de partage Lecture ou Modifier ; conserver le Contrôle total pour les administrateurs. Le droit effectif est l'intersection partage/NTFS. Retirer Everyone et les groupes génériques des dossiers sensibles après avoir vérifié les héritages.

Sur les dossiers sensibles, désactiver l'héritage de façon maîtrisée, garder SYSTEM et Administrators en Contrôle total, ajouter le groupe local de domaine approprié. Éviter les règles Deny si l'absence d'autorisation suffit ; elles peuvent provoquer des effets inattendus avec les appartenances multiples. Afficher seulement les ressources autorisées via l'énumération basée sur l'accès si activée, sans la considérer comme une protection d'accès.

## Recette positive et négative

usr.fin01 crée et relit un fichier fictif dans Finance ; usr.com01 est refusé sur ce même fichier. usr.rh01 accède à RH mais ne lit pas Finance. Un compte Direction lit Syntheses mais ne modifie pas sans autorisation prévue. Vérifier aussi l'accès direct au chemin UNC et les permissions effectives dans les propriétés NTFS, sans autoriser une ouverture de session utilisateur sur le DC. Conserver les ACL et les événements d'audit.

Modifier les groupes nécessite une déconnexion/reconnexion du compte testé. La preuve d'un refus doit indiquer identité, chemin, opération, heure et erreur ; masquer le nom d'utilisateur ne doit pas empêcher de comprendre son rôle. Ne placer aucune vraie donnée RH ou client dans les dossiers de test.

# Stratégies GPO et postes Windows

| GPO et liaison | Paramètres proposés | Preuve attendue |
|---|---|---|
| CC-Domaine-Comptes à la racine | Minimum 14 caractères ; complexité ; historique 24 ; verrouillage après 5 échecs pendant 15 min ; remise à zéro 15 min | Stratégie de domaine effective |
| CC-Postes-Securite à OU Postes | Pare-feu tous profils ; Defender ; écran verrouillé 10 min ; SMBv1 absent ; invité SMB interdit | gpresult et configuration locale |
| CC-Postes-Usage à OU Postes | Lecteurs réseau par groupe ; utilisateur sans admin local | Session métier et whoami /groups |
| CC-DC-Audit à Domain Controllers | Audit avancé authentification comptes gestion comptes et changements annuaire ; succès et échecs utiles | auditpol et événements DC |
| CC-Postes-Audit à OU Postes | Ouverture de session ; création processus avec ligne de commande si justifiée ; objets ciblés par SACL | Événements poste |
| CC-Tests-ACL à OU Tests si nécessaire | Réglages de démonstration bornés ; pas de politique de mot de passe supposée par OU | Sauvegarde et retrait après scénario |

Une politique de mot de passe de domaine s'applique aux comptes du domaine depuis la racine ; une GPO liée seulement à une OU d'utilisateurs ne fournit pas une politique de domaine différente. Une politique granulaire PSO peut être ajoutée plus tard à un groupe dédié si le besoin est démontré. Conserver la Default Domain Policy et la Default Domain Controllers Policy lisibles ; documenter toute modification.

## Mots de passe et privilèges

Choisir des phrases longues, uniques et non présentes dans les supports. Ne pas imposer une rotation fréquente sans justification ; modifier lors d'un incident ou d'un changement d'accès. Le seuil de verrouillage est un choix pédagogique exposant aussi à un déni de service : le tester uniquement sur tst.lock et mesurer l'impact.

La jonction au domaine peut ajouter Domain Admins aux administrateurs locaux : inventorier cette appartenance. Sur les postes uniquement, une GPO refuse aux comptes d'administration du domaine la session locale et RDP ; conserver un compte local de secours distinct et testé. Ne jamais lier ce refus aux contrôleurs de domaine. Windows LAPS est une extension pertinente pour le compte local du poste : activer seulement après préparation du schéma et contrôle des droits de lecture du secret. Ne pas l'annoncer opérationnel dans la recette initiale sans preuve.

## Validation et retour arrière

Lier une GPO à l'OU Postes, exécuter gpupdate /force, ouvrir une nouvelle session puis générer gpresult /h. Contrôler la valeur effective et le fonctionnement métier. Sauvegarder les GPO avant changement et noter le GUID. En cas de conflit, retirer la liaison fautive, actualiser et vérifier que le client et les accès AD fonctionnent encore.

# Durcissement et accès distant

## Hôte et MacBook

Conserver l'accès existant MacBook → Tailscale → RDP de l'hôte. Restreindre la politique du tailnet à l'identité autorisée et à l'hôte sur TCP 3389 ; examiner et retirer les autorisations générales qui pourraient conserver un accès trop large. Activer MFA chez le fournisseur d'identité et vérifier les appareils reconnus. La politique Tailscale et le pare-feu Windows sont deux contrôles distincts [S6].

Activer NLA, utiliser un compte d'administration de l'hôte distinct du domaine lab, maintenir Windows à jour et vérifier les règles RDP effectives. Ne pas publier 3389 sur la box. Ne pas installer Tailscale dans les VM, annoncer leurs sous-réseaux ou faire de l'hôte un exit node. Le MacBook ouvre une session sur l'hôte puis les consoles VM ; aucun accès réseau direct aux invités n'est nécessaire.

## Windows et pfSense

- Defender, pare-feu et mises à jour actifs ; aucune désactivation globale pour faciliter un scénario.
- SMBv1 retiré, SMB invité refusé, signature SMB vérifiée sur les éditions réellement utilisées ; conserver une politique cohérente avec les besoins métier.
- RDP invité désactivé si inutile ; administrations locales dans les consoles. Réduire les services superflus et comptes inutilisés.
- pfSense : secrets distincts, gestion HTTPS sans WAN, GUI réservée, sauvegarde chiffrée/protégée, version et règles exportées.
- ISO officielles avec empreintes ; disques et sauvegardes protégés par chiffrement quand disponible, avec clés de récupération stockées séparément.

## Choix de profondeur

Pas de SIEM ou d'IDS/IPS lourd sur 16 Go : utiliser l'audit Windows et les journaux pfSense, puis une analyse hors ligne. Sysmon est optionnel après choix d'une configuration restreinte et mesure de son coût ; ne pas l'installer sans objectif de détection. Un certificat LDAPS interne est une extension, pas une condition implicite du socle.

Les mesures Zero Trust retenues sont la vérification d'identité, le moindre privilège, la séparation des comptes et le refus réseau par défaut. Le laboratoire n'est pas une implémentation complète de Zero Trust : les flux DC/client restent dans un segment commun et le DC reste très privilégié. Présenter ces limites au jury.

Avant tout changement sur l'hôte qui touche le RDP ou Tailscale, disposer d'une session locale ou d'un accès console de secours. Le projet ne doit pas provoquer une perte de l'accès distant qui existe déjà.

# Menaces et matrice de risques

Notation de conception : probabilité P et impact I de 1 faible à 4 critique ; score P × I. 1 à 3 faible, 4 à 7 modéré, 8 à 11 élevé, 12 à 16 critique. Les scores après traitement sont estimés, non mesurés. Les risques de confinement bloquent les essais jusqu'à correction.

| ID et menace | P/I score initial | Traitement | Score résiduel estimé |
|---|---|---|---|
| R01 Évasion vers LAN personnel | 3/4 = 12 | Private ; WAN coupé en audit ; T01 à T04 | 1/4 = 4 |
| R02 Compromission compte admin | 3/4 = 12 | Comptes séparés MFA accès distant droits minimaux | 2/4 = 8 |
| R03 Accès indu fichiers RH/Finance | 3/3 = 9 | AGDLP ACL audit objets contre-tests | 1/3 = 3 |
| R04 Perte hôte ou SSD | 2/4 = 8 | Sauvegarde indépendante PRA mesuré | 2/3 = 6 |
| R05 Saturation RAM ou disque | 3/3 = 9 | Profils alternés seuils et marge de stockage | 1/3 = 3 |
| R06 Mauvaise GPO bloque métier | 3/3 = 9 | OU test sauvegarde déploiement progressif | 1/3 = 3 |
| R07 Journaux perdus ou altérés | 3/3 = 9 | Exports réguliers copies hachées séparées | 2/2 = 4 |
| R08 Simulation provoque indisponibilité | 2/4 = 8 | Cibles fictives arrêt rapide baseline et PRA | 1/3 = 3 |
| R09 DC unique indisponible | 3/3 = 9 | PRA ; limite de redondance explicitée | 2/3 = 6 |
| R10 Secrets présents dans preuves | 2/4 = 8 | Expurgation revue dossier jury | 1/4 = 4 |

## Responsables et traitement

Le porteur traite R01, R05 et R08 avant toute campagne. R02 et R09 restent les principales limites structurelles : budget et mémoire empêchent une redondance réaliste. La direction fictive accepte les scores résiduels uniquement pour le laboratoire ; une transposition en production exigerait une revue séparée, deux DC et une séparation des rôles.

## Menaces retenues

Utilisateur curieux ou mal autorisé, poste interne compromis, tentative de connexion répétée, mauvaise configuration de partage, erreur d'administration et panne de stockage. Kali représente un auditeur dans une zone dédiée, pas un attaquant autorisé à cibler des tiers. Le WAN et l'hôte sont des actifs à protéger, jamais des cibles de scan.

Tout nouvel incident modifie la matrice : identifier l'actif, la cause, le contrôle défaillant et le risque restant. Le dossier doit montrer pourquoi une mesure diminue un risque et quelles limites subsistent, au-delà de l'affichage d'un outil de sécurité.

# Scénarios contrôlés et règles de conduite

| Scénario | Action bornée | Signal et retour attendu |
|---|---|---|
| S01 Surface DC | Kali vers 10.77.10.10 ; scan TCP ciblé 53,88,135,389,445,636,3268 ; sans script exploit | Ports relevés ; règles retirées ; contre-test |
| S02 Erreur de droits | Ajouter un droit de lecture à un groupe test sur FinanceDemo uniquement ; lire un fichier fictif puis retirer | Accès avant ; refus après ; trace ACL |
| S03 Échecs de connexion | Cinq essais manuels erronés sur tst.lock via client ; pas de dictionnaire | Échecs authentification et verrouillage |
| S04 Trafic interzone interdit | Depuis Kali tenter une connexion TCP vers GUI pfSense et port non autorisé d'une cible lab | Refus journalisé corrélé |
| S05 Perte de fichier | Créer puis supprimer un fichier factice dans FinanceDemo ; restaurer depuis sauvegarde | Événement si SACL ; hash restauré identique |
| S06 Panne AD simulée | Arrêter proprement le DC ; constater DNS/auth fraîche indisponibles ; appliquer PRA ou redémarrer | Impact mesuré ; services validés au retour |

## Conditions avant scénario

Le porteur signe une fiche d'autorisation pédagogique comportant la date, les IP exactes, la durée, les outils et limites. Exporter baseline, sauvegarde et état réseau ; vérifier la déconnexion WAN. Tous les fichiers sont factices. Laisser la console pfSense et la gestion Hyper-V accessibles depuis l'hôte, hors réseau attaquant.

Créer pour S02 un partage FinanceDemo distinct, avec les mêmes ACL de référence que Finance, puis une SACL ciblée pour les identités test. S02 modifie uniquement FinanceDemo et un groupe test ; ne pas ouvrir les autres dossiers du laboratoire. S03 s'arrête au seuil prévu sur le compte test ; ne pas tenter d'autres utilisateurs. S06 ne confond pas connexion mise en cache et authentification fraîche : utiliser un compte test jamais connecté ou vérifier explicitement un service AD.

## Conditions d'arrêt immédiat

- IP hors périmètre, carte WAN reconnectée ou carte Kali reliée à un switch non autorisé.
- Perte d'administration, mémoire hôte disponible sous 1,5 Go ou espace libre sous le seuil prévu.
- Comportement non prévu, charge anormale, service AD cassé ou journaux non collectables.

Arrêter l'outil puis la VM Kali si nécessaire ; déconnecter les cartes concernées, conserver les journaux, traiter l'écart. Interdiction de malware réel, chiffrement destructeur, vol de secrets, brute force, hameçonnage de personnes et test sur le LAN personnel. Les scénarios valident des contrôles locaux sans chercher une compromission générale du domaine.

# Plan d audit et collecte

## Méthode

L'audit compare une baseline à la configuration durcie, avec mêmes versions, identités, cibles et commandes. Un écart est décrit par le comportement observé et sa preuve, puis rapproché d'une exigence. L'audit ne produit pas de score de sécurité global arbitraire et ne conclut pas à l'absence de vulnérabilités à partir d'un scan de ports.

| Domaine | Contrôle | Collecte |
|---|---|---|
| Réseau | Switches cartes routes WAN et absence de pont | Exports Hyper-V ; ipconfig/routes ; pfSense |
| AD | OU comptes inactifs privilèges groupes sensibles | Exports AD minimaux et horodatés |
| DNS/temps | Résolution SRV inverse et dérive | nslookup Resolve-DnsName w32tm |
| GPO | Liaisons valeurs appliquées conflits | Sauvegarde GPO gpresult auditpol |
| Fichiers | Droits partage/NTFS accès positifs/négatifs | Get-SmbShareAccess icacls captures test |
| Postes | Defender pare-feu services mises à jour | Commandes de statut et historique |
| Journaux | Audit effectif événement attendu conservation | EVTX pfSense logs manifeste SHA256 |
| PRA | Sauvegarde indépendante et reprise | Chronométrage hash données recette AD |

## Phase avant et phase après

Avant : relever la configuration réelle, vérifier le fonctionnement et, uniquement pour S02, introduire l'erreur bornée. Après : appliquer la correction, refaire exactement le test, vérifier les fonctions métier et conclure sur le risque résiduel. Enregistrer aussi les tests échoués, les indisponibilités et les limites de mesure.

## Fiche de constat

Identifiant Cxx ; exigence associée ; date et profil ; actif/IP ; situation observée ; preuve avant ; impact métier ; niveau de risque ; cause probable ; correction ; preuve après ; contre-test fonctionnel ; statut ouvert/corrigé/accepté ; responsable. Une capture d'écran seule ne prouve pas toute la chaîne : l'accompagner de l'export ou du journal natif pertinent.

Exporter les journaux avant tout retour de checkpoint et avant arrêt des VM pour PRA. Les exports bruts restent dans un dossier restreint ; le dossier jury reçoit les extraits nécessaires et expurgés. Une chaîne de preuve hachée améliore la traçabilité sans garantir à elle seule que le contenu source était authentique.

# Journalisation et détection

| Source | Événements ou données | But |
|---|---|---|
| DC Security | 4624/4625 connexions ; 4740 verrouillage ; 4771/4776 selon chemin d'authentification | S03 ; succès et échecs corrélés |
| DC Security | 4720 création ; 4726 suppression ; 4738 modification utilisateur ; 4728/4732/4756 ajouts groupes selon portée | Suivi identités et privilèges |
| DC objets | 4663 accès objet si audit et SACL ; 5140/5145 partages si sous-catégories actives | S02 et S05 ; accès aux fichiers ciblés |
| DC annuaire | 5136 si audit changements annuaire et SACL adaptée | Changements AD pertinents |
| Client Security | 4624/4625 ; 4688 si création processus activée | Contexte session et outil de test |
| Windows système | 1102 effacement Security ; erreurs DNS AD et sauvegarde dans leurs journaux | Altération traces et PRA |
| pfSense | Source destination port décision règle/interface horodatage | S04 ; flux refusés et autorisés utiles |

Les identifiants sont des événements attendus selon la sous-catégorie et le chemin réel ; une tentative Kerberos peut produire 4771 plutôt que le seul 4625 sur le DC [S8]. Activer l'audit avancé et son application prioritaire, puis faire un essai pour vérifier le fournisseur et le journal. Les refus fichier peuvent se manifester par 4656 ou 5145 selon l'opération et l'audit ; ne pas exiger systématiquement 4663 pour chaque refus.

## Conservation et corrélation

Dimensionner initialement Security à 256 Mo et System/Application à 64 Mo, puis ajuster au volume mesuré. Le comportement de remplissage et l'export quotidien doivent être consignés. Objectif : conserver 30 jours d'exports de séances, sous réserve de stockage ; export après chaque scénario, copie indépendante, empreinte SHA256 et accès restreint. pfSense utilise un tampon limité : exporter immédiatement les lignes pertinentes et la configuration des règles.

Conserver horodatage original et fuseau de chaque source, puis normaliser en UTC pour la chronologie ; présenter au jury les heures Europe/Paris. Contrôler w32tm, date Kali et pfSense avant chaque scénario. Associer les événements par identité, IP, règle et fenêtre horaire, sans interpréter une simultanéité comme une preuve de causalité.

## Règles de détection pédagogique

Alerte D01 : au moins cinq échecs sur tst.lock dans cinq minutes et/ou 4740. D02 : ajout inattendu à un groupe privilégié. D03 : modification d'ACL sensible suivie d'accès depuis un groupe non autorisé. D04 : flux AUDIT refusés vers une destination non ouverte. D05 : effacement du journal Security. Analyse manuelle ou script de lecture hors ligne ; aucun SOC 24/7 n'est revendiqué.

# Gestion des incidents et remédiation

## Procédure commune

- Détecter et qualifier : ouvrir INC-AAAA-MM-JJ-xx, identifier les symptômes, actifs, heures et preuves ; distinguer incident, essai prévu et panne.
- Contenir : suspendre le scénario, arrêter Kali, retirer la règle temporaire ; si un poste est suspect, déconnecter sa carte dans Hyper-V. Préserver l'administration par console.
- Préserver : exporter EVTX, journaux pfSense et configurations, calculer les empreintes, copier sur support indépendant. Ne pas revenir au checkpoint avant cette étape.
- Corriger : retirer le droit ou compte non autorisé, rétablir la GPO, patcher si une cause établie le justifie ; documenter chaque action et son heure.
- Rétablir : confirmer AD/DNS, accès métier et refus attendus ; observer les nouveaux événements. Restaurer uniquement si nécessaire.
- Clore : chronologie, cause, impact, tests de reprise, risque restant et prévention ; mettre à jour le dossier.

| Incident pédagogique | Containment | Remédiation et preuve |
|---|---|---|
| INC01 Accès FinanceDemo indu | Retirer règle audit si accès réseau ; fermer session test | Corriger ACL groupe ; nouvelle session ; refus et accès Finance légitime |
| INC02 tst.lock verrouillé | Stopper essais ; vérifier qu'aucun compte réel n'est touché | Attendre durée ou déverrouiller via compte délégué ; vérifier 4740 et retour |
| INC03 WAN connecté pendant audit | Stop Kali ; déconnecter WAN immédiatement | Revoir topologie et fiche de passage ; T01 à T04 obligatoires |
| INC04 Fichier factice perdu | Préserver traces et éviter écriture dans dossier | Restaurer version sauvegardée ; hash et droits conformes |

## Niveaux et délais cibles

Critique : rupture de confinement, arrêter immédiatement et suspendre l'audit. Élevé : privilège indu ou perte AD, contenir dans les 5 minutes de détection en séance. Modéré : défaut de journalisation ou GPO isolée, corriger avant le prochain scénario. Ces délais sont des objectifs à mesurer ; la détection n'est pas continue hors séance.

Le compte administrateur hôte, le secret DSRM et les sauvegardes restent hors des cibles. Si un secret de test a été exposé, le renouveler et retirer toute preuve qui le contient. Ne pas appliquer automatiquement des remédiations proposées par une IA ou un outil d'analyse ; l'administrateur vérifie la cause et teste le changement dans le laboratoire.

# Sauvegardes checkpoints et PRA

## Deux mécanismes distincts

Checkpoint : retour rapide d'un exercice sur le même hôte ; il n'est ni indépendant du disque ni une sauvegarde. Utiliser des checkpoints Production pour les Windows quand les intégrations le permettent ; éviter l'état mémoire d'un DC. Pour une baseline cohérente, arrêter proprement client et DC, puis enregistrer le jeu pfSense/DC/client avant scénario. Exporter les preuves avant toute restauration. Les protections VM-Generation ID ne remplacent pas une sauvegarde AD [S3].

Sauvegarde : Windows Server Backup ou solution AD-compatible pour état système et volumes critiques du DC, plus données ; conserver hors VHDX et hors SSD hôte. Export à froid des VM pour la reconstruction complète du laboratoire, config.xml pfSense et sauvegardes des GPO. Copier les exports sur support indépendant, vérifier lisibilité et empreintes ; protéger secrets, clés et DSRM [S9].

| Objet | Fréquence cible | RPO cible | RTO cible |
|---|---|---|---|
| Données fictives | Après séance et avant scénario | 1 séance ou 24 h | 30 min pour un fichier |
| DC état système et volumes | Baseline validée puis changements majeurs | 24 h de travaux | 2 h pour reprise AD lab |
| VM et configuration pfSense | Jalons validés ; avant modification réseau | Dernier jalon validé | 4 h pour laboratoire complet |

## Runbook de reprise

1. Déclarer l'incident et relever le dernier point sain. 2. Isoler les réseaux, WAN déconnecté ; arrêter toutes les VM d'origine. 3. Vérifier disponibilité des sauvegardes, mots de passe et espace disque. 4. Restaurer pfSense et DC hors ligne sur réseaux Private, sans créer de DC homonyme actif. 5. Pour perte AD, utiliser la procédure supportée de restauration état système/forêt avec DSRM ; une restauration de fichiers VHDX non maîtrisée n'est pas une procédure AD [S9].

6. Vérifier démarrage AD DS, zones DNS, partages SYSVOL/NETLOGON, événements et dcdiag. 7. Démarrer le client, vérifier canal sécurisé, authentification fraîche, GPO et ACL. 8. Restaurer les données, comparer hashes et droits. 9. Mesurer les durées, écart RPO, erreurs et actions. 10. Maintenir l'ancienne instance arrêtée ; retirer les checkpoints inutiles après validation et surveiller les fusions/disque.

Tester séparément la perte de fichier et la reconstruction à froid. Pour une répétition parallèle, employer de nouveaux switches Private dédiés et des VM isolées, sans liaison au domaine original. Avec 16 Go, arrêter l'environnement original ; pas de doubles ensembles simultanés. Les objectifs RTO/RPO restent non validés tant que T14/T15 ne sont pas exécutés.

# Recette fonctionnelle et isolation

Tous les tests de cette page ont le statut NON EXÉCUTÉ. Reporter le résultat réel, la date, le profil, les versions et le lien de preuve dans le registre ; un test bloqué ou non exécuté ne compte pas comme réussi.

| ID | Procédure | Résultat attendu et preuve |
|---|---|---|
| T01 | Lister switches et toutes cartes VM ; vérifier l'hôte et les routes | LAN/AUDIT Private ; pas de pont/ICS ; exports |
| T02 | Inventorier cartes DC client Kali et pfSense | Une carte par cible ; pfSense seul route ; MAC associées |
| T03 | En audit relever WAN déconnecté ; tester URL externe depuis cible lab | Pas d'accès externe ; capture cartes et échec contrôlé |
| T04 | Vérifier règles refus hôte/non public et IPv6 ; compteurs lab | Aucun chemin vers réseau personnel ; revue topologie sans scan du LAN |
| T05 | Démarrer profil métier et mesurer RAM 10 min | 9 Go VM ; au moins 1,5 Go hôte disponible ; relevé |
| T06 | Résoudre DC A/PTR et SRV _ldap._tcp.dc._msdcs.ad.cybercorp.test | Réponses cohérentes depuis client ; sortie commande |
| T07 | Connecter compte neuf ; contrôler canal sécurisé et dcdiag | Authentification fraîche ; services AD sains |
| T08 | Finance crée fichier ; Commercial tente même opération | Finance admis ; Commercial refusé ; trace et ACL |
| T09 | Direction lit Syntheses puis tente écriture non autorisée | Lecture réussie ; écriture refusée |
| T10 | Appliquer GPO et générer gpresult ; vérifier pare-feu | Valeurs effectives conformes ; rapport |
| T11 | MacBook ouvre RDP hôte ; revue politique et absence routes invités | Hôte seul joignable pour cet usage ; aucune route lab annoncée |
| T12 | S03 produit événement ; comparer horloges | Compte test identifié ; dérive cible sous 5 s |
| T13 | Exporter logs et les relire ; vérifier SHA256 copie | Exports lisibles et hashes identiques |
| T14 | Supprimer fichier factice puis restaurer sauvegarde | Contenu/hash et ACL corrects ; temps mesuré |
| T15 | Reprise DC/lab depuis copie indépendante hors original | AD DNS client GPO ACL fonctionnels ; RTO/RPO mesurés |

T04 démontre l'isolation par configuration et tests sur destinations du laboratoire. Il ne nécessite aucun scan du réseau domestique. En maintenance, vérifier les blocages dans les règles et leurs compteurs sur une destination fictive réservée avant toute sortie réelle. Une réussite en audit ne vaut pas validation du mode maintenance.

# Tests de sécurité avant et après

| Test | Avant prévu | Correction | Après attendu |
|---|---|---|---|
| S01 Surface DC | Scan borné sur ports autorisés pour observer la surface nécessaire | Retirer règles AUDIT ; limiter services inutiles | Depuis Kali refus ; client AD toujours fonctionnel |
| S02 FinanceDemo | Compte test non financier lit après droit volontairement erroné | Retirer groupe incorrect des ACL et revoir héritage | Accès test refusé ; Finance peut lire/écrire |
| S03 Authentification | Cinq échecs sur compte test ; audit activé avant essai | Vérifier politique et traitement verrouillage ; pas d'affaiblissement | Événement/identité visibles ; récupération conforme |
| S04 Filtrage | Flux vers port lab non autorisé ; aucune ouverture large | Revoir ordre/alias si le trafic passe | Refus journalisé ; flux légitime préservé |
| S05 Données | Fichier connu et hash enregistré ; suppression factice | Restauration sauvegarde et ACL | Hash identique ; temps et RPO consignés |
| S06 AD indisponible | DC arrêté ; échec service frais ; cache expliqué | Redémarrage ou reprise selon objectif de l'essai | Services AD et authentification fraîche validés |

## Règles de comparaison

Enregistrer les commandes exactes, les paramètres, le compte, les règles temporaires et la fenêtre de temps. Pour S01, la fermeture des ports depuis Kali ne signifie pas que les services AD sont désactivés ; elle démontre le filtrage interzones. Vérifier toujours que le client métier peut encore utiliser AD. Les ports 636/3268 peuvent être fermés selon la configuration ; ne pas les annoncer ouverts sans mesure.

L'audit avant ne doit pas affaiblir l'environnement entier : seules les erreurs artificielles définies sont introduites. Le pare-feu et Defender restent actifs. Répéter un test seulement après une correction ou si le résultat est ambigu ; consigner les tentatives pour éviter de sélectionner uniquement les résultats favorables.

## Formulaire de résultat à utiliser

Test et scénario : ____ ; date et heure avec fuseau : ____ ; profil : ____ ; identité et cible : ____ ; versions : ____ ; commande/action : ____ ; préconditions : ____ ; résultat observé : ____ ; preuve : ____ ; conformité : réussi/échoué/bloqué/non exécuté ; effet métier : ____ ; anomalie et action : ____ ; validateur : ____.

Le résultat initial et le contre-test doivent avoir des fichiers de preuve distincts. Si une démonstration échoue le jour de la soutenance, expliquer le symptôme, isoler la cause et afficher les preuves historiques authentiques ; ne pas remplacer le résultat observé par la valeur attendue.

# Indicateurs et critères d acceptation

| KPI | Calcul et source | Cible proposée |
|---|---|---|
| K01 Recette socle | Tests T01 à T15 réussis / 15 ; tous les autres statuts restent au dénominateur | 100 % pour acceptation complète |
| K02 Confinement | T01 à T04 et T11 conformes ; inspection des cartes | 5/5 ; aucun écart toléré |
| K03 ACL | Accès autorisés/refus conformes / cas prévus T08 T09 S02 | 100 % ; après correction |
| K04 Détection | Scénarios devant générer une trace effectivement retrouvés / exécutés concernés | 100 % S03 et S04 ; autres selon SACL |
| K05 Délai détection | Heure qualification moins heure premier signal ; mesure manuelle | Moins de 5 min en séance |
| K06 Reprise fichier | Temps du début de restauration au fichier validé | Au plus 30 min ; hash identique |
| K07 Reprise AD/lab | Temps reprise AD puis labo ; procédure T15 | AD 2 h ; lab 4 h |
| K08 Ressources | Minimum RAM hôte et espace disque pendant séance | RAM >= 1,5 Go ; disque >= 20 % |
| K09 Traçabilité | Constats avec preuve avant/correction/après / constats clos | 100 % |
| K10 Risques | Nombre risques critiques ouverts et contrôle des hauts | 0 critique ; hauts explicitement acceptés |

Ces seuils sont des objectifs pédagogiques, pas des performances mesurées. Indiquer « non mesuré » quand aucune observation n’existe. K04 ne peut pas être à 100 % si aucun scénario concerné n’a été exécuté : afficher « non calculable ». La détection manuelle n’a pas de garantie hors séances.

## Acceptation du socle

- Confinement validé avant attaque, profils mémoire respectés et accès distant hôte opérationnel.
- AD DNS GPO et ACL démontrés avec tests positifs et négatifs ; aucune permission sensible non justifiée.
- Journalisation effective avec exports lisibles et preuves avant/après ; aucun secret dans le dossier jury.
- Sauvegarde indépendante restaurée au moins une fois ; écarts RTO/RPO explicités.
- Dossier et inventaire alignés sur l’état réellement présenté ; toute exception ouverte attribuée et justifiée.

Un échec de confinement interdit la soutenance avec attaque en direct. Un échec PRA permet de présenter un travail incomplet avec ses limites, mais ne satisfait pas l’acceptation complète. Le bonus GenOS n’entre ni dans le dénominateur de K01 ni dans la validation du socle.

# Matériel budget et charge de travail

| Poste | Hypothèse | Budget indicatif |
|---|---|---|
| Mini-PC 16 Go et MacBook | Déjà possédés selon porteur ; modèles non inspectés | 0 € achat additionnel prévu |
| Windows 11 Pro hôte | Déjà présent ; droit à confirmer | 0 € si licence valide |
| Windows Server 2025 et client | Évaluation/droit pédagogique à confirmer ; production exclue | 0 € temporaire si conditions remplies |
| pfSense CE et Kali | Logiciels gratuits ; support commercial non inclus | 0 € licence envisagée |
| Support sauvegarde 1 To | Achat facultatif si aucun support indépendant disponible | 60 à 100 € enveloppe |
| Marge matériel | Câbles stockage ou ajustement | 20 à 40 € |
| Électricité | 60 h × 0,06 kW × 0,25 €/kWh, hypothèse | 0,90 € |
| Total additionnel | Hors licences permanentes ; estimation de conception | Environ 81 à 141 € |

Les montants sont une enveloppe de planification, pas des devis ni des prix vérifiés. Avant achat, demander un prix local et vérifier la compatibilité. Le coût peut être proche de zéro si le support de sauvegarde existe. Aucun coût de licence perpétuelle n'est inventé : chiffrer séparément si les droits temporaires ne couvrent pas les dates du projet.

| Travail | Charge prévue |
|---|---|
| Cadrage inventaire sources et conception | 6 h |
| Construction VM réseau AD et client | 12 h |
| Groupes ACL GPO et sécurité | 10 h |
| Audit journalisation et scénarios | 8 h |
| Remédiation contre-tests et PRA | 8 h |
| Preuves dossier et préparation orale | 10 h |
| Marge pour incidents et reprises | 6 h |
| Total | 60 h sur 4 à 6 semaines |

## Arbitrages

Priorité au socle et aux preuves ; ne pas acheter un serveur lourd ou lancer un SIEM pour améliorer seulement l'apparence du projet. GenOS est limité à 4 h supplémentaires après recette socle, et utilise de préférence le MacBook ou une analyse de fichiers hors ligne. Si la charge augmente, supprimer le bonus avant de réduire les tests de confinement et de PRA.

# Jalons et suivi du projet

Planning relatif au démarrage réel, sans inventer une date de soutenance. Les heures comprennent la marge. Une phase n'est validée que lorsque ses preuves sont archivées ; avancer un outil ne remplace pas le jalon.

| Jalon | Fenêtre et charge | Livraison et condition de sortie |
|---|---|---|
| J0 Cadrage | Semaine 1 • 6 h | Périmètre matériel licences IP risques ; aucun conflit réseau |
| J1 Infrastructure | Semaine 1/2 • 12 h | VM switches pfSense AD/client ; T01 à T07 documentés |
| J2 Sécurité | Semaine 2/3 • 10 h | ACL GPO audit ; T08 à T13 et sauvegarde baseline |
| J3 Audit | Semaine 3/4 • 8 h | Scénarios autorisés ; constats avant et journaux exportés |
| J4 Remédiation et PRA | Semaine 4 • 8 h | Contre-tests ; T14 T15 ; risques résiduels |
| J5 Soutenance | Semaine 5 • 10 h | Dossier preuves expurgées répétition orale |
| Réserve | Semaine 5/6 • 6 h | Correction des écarts bloquants et mise à jour inventaire |

## Dépendances et contrôle de changement

AD dépend du DNS et de l'IP fixe ; GPO et ACL dépendent des groupes ; journalisation doit précéder les scénarios ; sauvegarde et confinement précèdent l'audit. Le PRA dépend d'une copie indépendante lisible. Le bonus dépend de l'acceptation du socle et ne peut retarder J4.

Chaque changement est inscrit dans CHG-xx : motif, objets modifiés, sauvegarde préalable, plan de retour, contrôle métier et preuve. Garder un journal des décisions : pourquoi LAN Private, pourquoi Kali alternée, pourquoi partage sur DC en lab et pourquoi pas de SIEM lourd. Mettre à jour le diagramme après toute variation des cartes ou préfixes.

## Gestion des écarts

Si 4 Go DC/client rendent l'hôte trop lent, fermer les logiciels inutiles, raccourcir la démonstration et utiliser les profils alternés ; ne pas descendre le client sous ses exigences de base. Si stockage insuffisant, exporter et nettoyer les checkpoints avec Hyper-V après validation, sans supprimer les fichiers AVHDX manuellement. Si accès distant instable, répéter localement et préparer une présentation à partir de preuves authentiques.

Le porteur tient un registre simple : jalon, date prévue, date réelle, statut, blocage, prochaine action. Les dates réelles et heures consommées seront renseignées au fur et à mesure. Le dossier fourni aujourd'hui constitue la conception initiale, pas le compte rendu de réalisation.

# Dossier de preuves et modèles

```
CyberCorp_Preuve/
  00_Index/          index.csv  manifeste_sha256.csv
  01_Conception/     dossier  diagramme  risques  inventaire
  02_Reseau/         switches  cartes  routes  regles_pfsense
  03_AD_DNS/         OU  groupes  membres  DNS  dcdiag
  04_GPO_ACL/        sauvegardes_GPO  gpresult  ACL
  05_Audit_Avant/    S01 ... S06  exports_bruts_restreints
  06_Remediation/    C01 ... Cxx  changements
  07_Audit_Apres/    contre_tests  journaux
  08_PRA/           sauvegardes_manifestes  recette_reprise
  09_Soutenance/    extraits_expurges  scenario_oral
  10_GenOS/         entrees_expurgees  sorties  verification
```

## Nommage et index

Nom conseillé : AAAAMMJJ_HHMMSS_UTC_T08_AVANT_CC-DC01_acl.txt. Index : ID, exigence/test, date UTC, source, version, auteur, profil, action, résultat réel, chemin relatif, SHA256, classification et état d'expurgation. Conserver les noms de VM et identifiants fictifs pour relier les pièces.

Capturer avant et après, avec cadrage suffisant pour identifier l'action. Compléter avec sorties texte et journaux natifs. Les captures de mots de passe, clés Tailscale, jetons, DSRM et secrets de sauvegarde sont exclues. Les fichiers config.xml et GPO bruts peuvent contenir des informations sensibles : garder une version restreinte et produire un extrait jury.

## Fiches minimales

| Document | Champs à renseigner |
|---|---|
| Inventaire | Actif nom rôle OS version RAM CPU disque IP switch MAC patchs date |
| Autorisation scénario | ID cible IP compte actions durée WAN déconnecté arrêt prévu signataire |
| Constat | ID exigence preuve impact cause correction contre-test statut risque |
| Incident | ID début signal qualification containment actions fin impact cause |
| PRA | Sauvegarde date intégrité étapes temps résultats AD/DNS/ACL RPO/RTO |
| Acceptation | Test résultat date preuve validateur réserve décision |

## Ce qui est livré et ce qui reste à constituer

Livré : conception complète, plan de configuration, scénarios, recette et modèles. À constituer par réalisation : inventaire exact, exports AD/GPO/ACL, règles pfSense appliquées, EVTX, captures avant/après, sauvegardes et mesures PRA. Le dossier ne contient pas de fausses captures ni d'indicateurs remplis artificiellement.

# Déroulé de soutenance

Format proposé de 20 minutes, à adapter à la durée officielle Guardia, puis questions. Préparer une démonstration entièrement hors ligne, les VM prêtes dans le profil métier, et des preuves authentiques en secours. Ne jamais démarrer les quatre VM pour gagner du temps de transition.

| Temps | Séquence | Message et support |
|---|---|---|
| 0 à 2 min | Contexte et objectifs | 25 employés fictifs ; actifs sensibles ; contraintes réelles |
| 2 à 5 min | Architecture | Diagramme ; switches Private ; Tailscale vers hôte ; WAN coupé |
| 5 à 8 min | Identités et accès | OU AGDLP ; compte Finance admis et Commercial refusé |
| 8 à 11 min | Durcissement et traces | GPO effective ; événement de compte test ; extrait pfSense |
| 11 à 14 min | Avant et après | S02 ACL bornée ; constat ; correction ; contre-test |
| 14 à 17 min | PRA et résultats | Méthode sauvegarde ; preuve de restauration et mesures réelles |
| 17 à 19 min | Risques et limites | Hôte/DC uniques ; profils RAM ; partage/DC ; améliorations |
| 19 à 20 min | Conclusion du projet | Exigences satisfaites et réserves ; bonus si temps |

## Démonstration conseillée

En direct : montrer les switches, WAN déconnecté, session Finance et accès refusé Commercial ; afficher gpresult et un journal déjà préparé. Pour Kali : arrêter le client avant son démarrage, ou montrer les preuves de la campagne réalisée et le profil mémoire correspondant. La restauration complète est présentée par chronologie et preuves mesurées ; ne pas lancer une procédure de plusieurs heures devant le jury.

## Questions à préparer

- Pourquoi pfSense ne voit-il pas les flux client/DC ? Ils partagent le même segment ; les contrôles Windows complètent le filtrage interzones.
- Pourquoi le WAN n’est-il pas External ? Le réseau personnel ne doit pas devenir le segment d’attaque ; maintenance via NAT contrôlé et audit hors ligne.
- Checkpoint ou sauvegarde ? Le premier facilite un exercice ; la seconde doit permettre une reprise depuis un support indépendant.
- Zero Trust ou domaine AD ? Modèle d’autorisation et de confiance d’un côté ; service d’identité Windows de l’autre.
- Quelles améliorations en production ? Deux DC distincts, serveur de fichiers séparé, segmentation clients/serveurs et collecte indépendante.

Ne présenter que les résultats réalisés. Si T15 n’a pas été exécuté, annoncer que le PRA est conçu mais non validé. GenOS tient dans une courte illustration après le socle ; il ne remplace pas l’analyse technique ni la preuve de correction.

# Bonus GenOS en lecture seule

## Hypothèse explicite

La référence ne précise ni le produit ni la version GenOS. Le dossier traite donc GenOS comme un assistant d'analyse optionnel, sans affirmer ses capacités réelles. L'intégration n'est entreprise que si l'outil permet l'import contrôlé de fichiers, le retrait de données sensibles et un mode sans actions sur l'infrastructure. S'il ne le permet pas, le bonus est abandonné.

## Architecture de moindre privilège

Exécuter GenOS hors des VM cibles, idéalement sur le MacBook, après export. Fournir uniquement des copies expurgées d'inventaires, de règles, de GPO et de journaux fictifs. Aucun compte AD, accès RDP, clé Tailscale, connecteur en écriture ni secret pfSense. Le répertoire source fourni est en lecture seule ; les sorties vont dans un répertoire distinct. Si cloud, vérifier les paramètres de conservation avant import ; ne fournir que des données fictives et non sensibles.

Les journaux sont des données non fiables : tout texte demandant d'exécuter une commande ou de changer une règle doit être ignoré. GenOS peut proposer des hypothèses et un résumé, jamais exécuter une remédiation. Les recommandations sont revues par le porteur et comparées aux exports canoniques.

## Vérification déterministe

| Règle locale | Entrée canonique | Décision fixe |
|---|---|---|
| V01 Réseaux cibles | Inventaire cartes et switches exporté | Échec si cible reliée à External/Internal/Default Switch |
| V02 WAN audit | Export carte pfSense avec profil audit | Échec si WAN a un SwitchName non vide |
| V03 Groupes privilégiés | Export membres Domain Admins | Échec si membre métier inattendu ; liste admise explicite |
| V04 FinanceDemo | ACL partage et NTFS ; liste admise | Échec si un groupe non admis reçoit Lecture/Modifier |
| V05 Preuves | Index plus fichiers et hashes | Échec si fichier absent ou hash différent |

Ces règles doivent être implémentées dans un vérificateur local indépendant et versionné ; l'IA ne constitue pas le vérificateur. Définir les listes admises à partir de la conception, figer entrées et SHA256, produire rapport PASS/FAIL avec identifiant et valeur observée. Les contrôles statiques V01/V02 ne remplacent pas les tests réseau dynamiques T01 à T04.

## Recette du bonus

G01 : prouver l'absence de droit d'écriture et d'identifiants fournis. G02 : déposer dans une copie un écart connu d'ACL et le faire détecter par V04. G03 : rejouer V01 à V05 sur les mêmes entrées pour un rapport identique. G04 : comparer chaque assertion GenOS aux règles et preuves ; compter les affirmations non étayées. Toutes ces opérations sont à réaliser. Une alerte IA seule ne suffit pas ; un faux positif est consigné comme tel.

# Commandes de vérification

Exemples à adapter et exécuter manuellement sur le bon système avec droits suffisants. Commandes de lecture sauf export de fichiers ; pas de script qui modifie automatiquement l'hôte. Les chemins de sortie doivent exister et rester dans le dossier de preuves restreint.

### Hôte Hyper V et réseau

```
Get-VMSwitch | Select-Object Name,SwitchType
Get-VMNetworkAdapter -VMName CC-PFS01,CC-DC01,CC-W11-01,CC-KALI01 |
  Select-Object VMName,Name,SwitchName,MacAddress,Status
Get-NetNat
Get-NetNatStaticMapping
Get-NetIPConfiguration
Get-NetRoute -AddressFamily IPv4
Get-NetIPInterface | Select-Object InterfaceAlias,AddressFamily,Forwarding
Get-CimInstance Win32_OperatingSystem |
  Select-Object TotalVisibleMemorySize,FreePhysicalMemory
```

### Client et contrôleur de domaine

```
ipconfig /all
Resolve-DnsName CC-DC01.ad.cybercorp.test
Resolve-DnsName -Type SRV _ldap._tcp.dc._msdcs.ad.cybercorp.test
w32tm /query /status
whoami /groups
gpresult /h C:\Preuves\gpresult.html
auditpol /get /category:*
Get-NetFirewallProfile
Get-MpComputerStatus
# Client membre uniquement
Test-ComputerSecureChannel -Verbose
# DC uniquement
dcdiag /test:DNS /v
Get-ADGroupMember "Domain Admins"
Get-SmbShareAccess -Name Finance
icacls D:\Partages\FinanceDemo
```

### Kali et conservation des preuves

```
# S01 seulement, WAN coupe, cible autorisee
nmap -sT -Pn -p 53,88,135,389,445,636,3268 --max-rate 10 \
  -oA S01_avant_dc 10.77.10.10
# Windows : export natif et empreinte
wevtutil epl Security C:\Preuves\DC_Security.evtx
Get-FileHash C:\Preuves\DC_Security.evtx -Algorithm SHA256
```

Le scan -sT évite les scripts et exploits ; il ne prouve pas qu'un service est vulnérable. Ne pas élargir la cible à un sous-réseau, ni utiliser les adresses réelles du réseau personnel. Comparer les hashes après copie ; noter les horaires et configurations. Les noms localisés des groupes AD peuvent différer : identifier le groupe Domain Admins par SID se terminant en -512 si nécessaire.

# Sources et glossaire

Documentation primaire consultée le 8 octobre 2026. Les références étayent les principes et exigences ; vérifier les détails selon les versions installées. Le schéma, les budgets, risques et valeurs cibles sont des choix de conception propres à CyberCorp.

[S1] Microsoft Learn • Set up a NAT network
Consulter la documentation officielle en ligne

[S2] Netgate • Virtualizing pfSense with Hyper V
Consulter la documentation officielle en ligne

[S3] Microsoft Learn • Virtualizing domain controllers with Hyper V
Consulter la documentation officielle en ligne

[S4] Microsoft Learn • Windows 11 requirements
Consulter la documentation officielle en ligne

[S5] Netgate • Rule Methodology
Consulter la documentation officielle en ligne

[S6] Tailscale • Access control
Consulter la documentation officielle en ligne

[S7] Microsoft Learn • Service overview and network port requirements
Consulter la documentation officielle en ligne

[S8] Microsoft Learn • Advanced security audit policy settings
Consulter la documentation officielle en ligne

[S9] Microsoft Learn • AD Forest Recovery Guide
Consulter la documentation officielle en ligne

[S10] NIST • SP 800 207 Zero Trust Architecture
Consulter la documentation officielle en ligne

[S11] IETF • RFC 2606 Reserved Top Level DNS Names
Consulter la documentation officielle en ligne

## Glossaire

AD DS : annuaire Windows. DNS : résolution de noms. OU : unité d’organisation. GPO : stratégie de groupe. ACL : liste de contrôle d’accès. AGDLP : comptes, groupes globaux, groupes locaux de domaine, permissions. WAN : zone de sortie. NAT : traduction d’adresses. NLA : authentification réseau préalable au RDP. DSRM : mode de restauration AD. RPO : perte de données maximale visée. RTO : durée de reprise visée. SACL : règles d’audit d’accès. EVTX : format de journal Windows. KPI : indicateur de suivi.